

Onboarding and rotating local admin credentials for AWS DMZ Windows servers

Agent-side rotation using CyberArk EPM Credentials Rotation with Loosely Connected Devices, with sessions brokered by PSM. Built from shipped product features apart from one API call.

Document control

Status	Draft, four product questions open
Version	0.9
Traces to	Requirements spec v0.6
Vault target	PAM Self-Hosted 14.2, PVWA 10.2 or later
New licence	EPM Credentials Rotation
Custom code	One PVWA REST call

1. Scope

Windows servers in the AWS DMZ are built from an AMI carrying a hardcoded local administrator password, which is shared directly with the teams that need it. They are not joined to Active Directory, so no domain account exists to reconcile against. This design replaces that with a unique per-machine credential held in the CyberArk Vault and reached only through a recorded session.

In scope: Windows Server instances in the AWS DMZ, the local account used for administrative access, and the full lifecycle from build to termination across every AWS account and region where these instances run. Out of scope: domain-joined servers, Linux, AWS IAM identities and end-user workstation privilege management.

Which local account is managed is still open. The current build creates a purpose-named account and adds it to the Administrators group, and says nothing about the built-in Administrator. This design works either way, which is one reason it was chosen.

2. The current pipeline

The arrangement this design replaces. Terraform sets the account at boot, a central Ansible controller reaches into the instance over WinRM to rotate it, and the result lands in AWS Secrets Manager where people and applications read it directly.

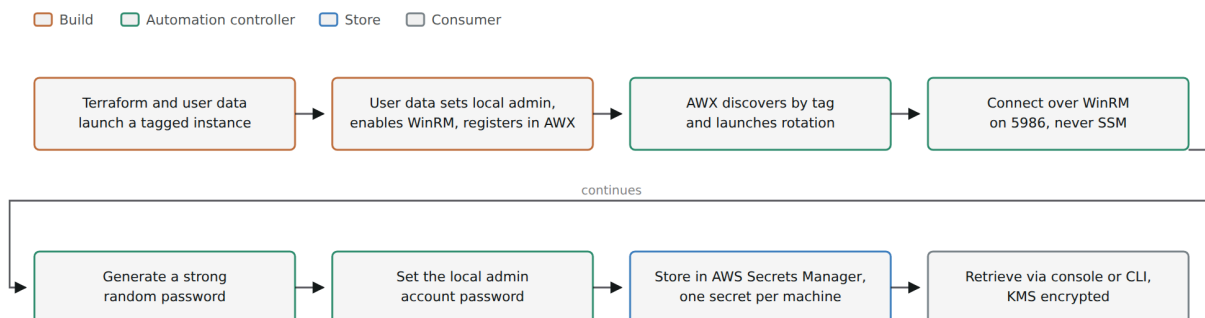


Figure 1. The credential is generated by the controller, applied over an inbound WinRM connection, and stored outside the Vault where it is read directly. Three of the four requirement failures in section 7 are visible here: the store is not the Vault, retrieval is not brokered, and the controller holds a working credential.

At organisation scale

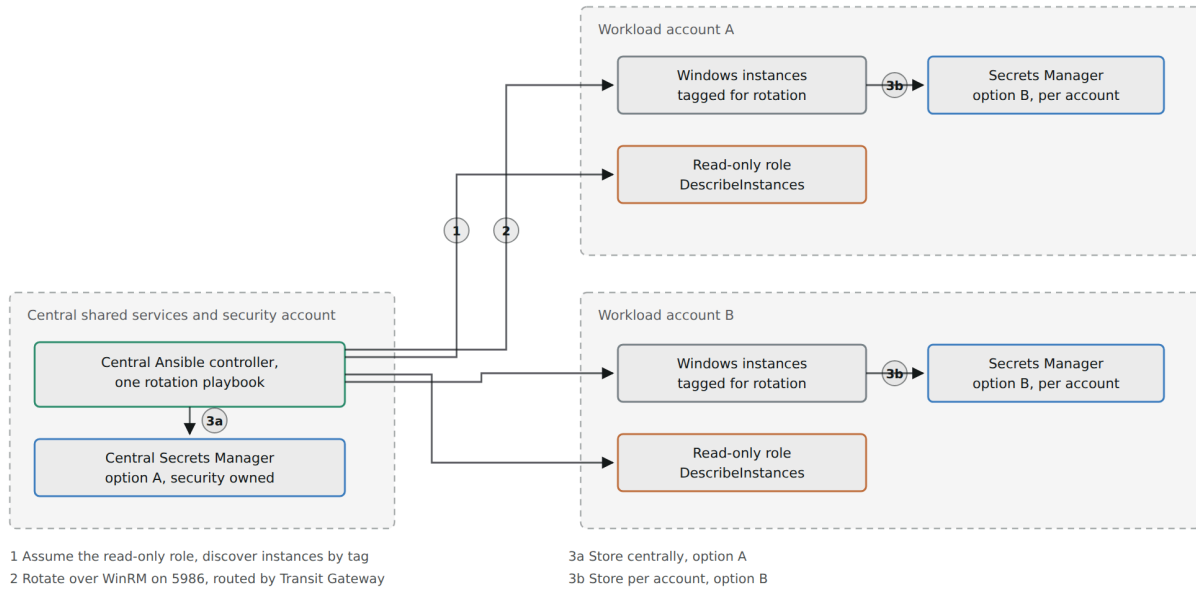


Figure 2. Every workload account is reached inbound from one central controller. The controller holds a credential for every instance it manages, and the store is chosen per account rather than being a single authority.

3. The design

The EPM agent on the instance owns the credential. It contacts PVWA over HTTPS, retrieves the credential PVWA generated, sets it on the local account and confirms. The agent never needs to know the current password, which is what removes the bootstrap problem rather than solving it: no key pair, no decryption step, no credential passing through the build pipeline, and nothing to dispose of afterwards. Rotation runs on the same path for the life of the instance, so nothing ever connects inbound to manage a credential.

Sessions are unchanged. ClientAPI launches through PSM against the vault-held credential, which keeps REQ04 intact and needs no work on the ClientAPI side.

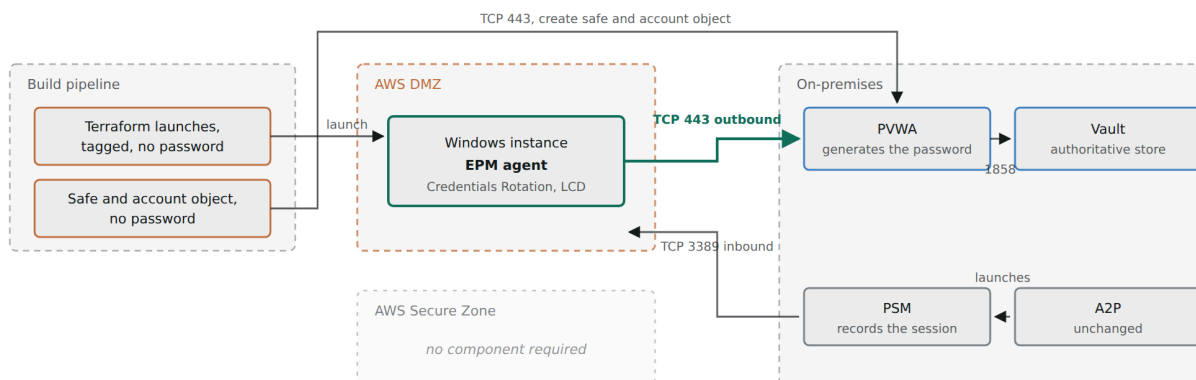


Figure 3. The credential is created by PVWA and applied locally by the agent, so nothing outside the Vault ever holds it and nothing connects inbound to manage it. The highlighted path is the one that replaces the entire bootstrap and rotation machinery of the current pipeline.

Components

Component	Placement	Role	Status	Serves
Digital Vault	On-premises	Authoritative credential store	Existing	REQ01
PVWA	On-premises	Policy, and the API endpoint the agent calls. Generates each new password	Existing, 10.2 or later	REQ03
PSM	As deployed	Isolated recorded RDP sessions, launched by ClientAPI	Existing	REQ03, REQ04
EPM agent with Credentials Rotation and LCD	Golden AMI	Sets and rotates the local credential, reports outbound	New, separate entitlement	REQ08, REQ09
Windows Loosely Device platform	PVWA	Rotation policy and schedule for these accounts	Ships with PVWA	REQ09
CyberArk Terraform provider, cyberark_pvwa_safe	Build pipeline	Safe provisioning from the existing Terraform run	New, no licence	REQ16, REQ18
PVWA REST call, POST /API/Accounts	Build pipeline	Creates the account object per instance: FQDN, username, platform, no password	New, the only custom step	REQ17, REQ20
Accounts Discovery	Existing platform	Periodic sweep reporting any in-scope instance with no managed account	Existing	REQ19, REQ28
Secrets Hub	Service	One-way sync of the vault credential into AWS Secrets Manager	Only if applications consume	REQ05, REQ01

The one custom step

LCD requires the account object to exist in PVWA, with the device FQDN and the exact local account username, before the agent can act on it. Nothing creates it automatically, and no product closes this gap. Discovery cannot, because a scan has to authenticate to the target to enumerate local accounts and onboarding rules then rely on the platform reconcile account, which on a machine with no domain membership is the account being created. The CyberArk

Terraform provider cannot either: it exposes `cyberark_aws_account`, `cyberark_azure_account` and `cyberark_db_account` only, all requiring a secret value, with no Windows local account resource.

So one documented API call runs in the build. Use CyberArk's published `psPAS` or `epv-api-scripts` from a Terraform local-exec, or Identity Flows if the SaaS platform is adopted. No credential passes through it, so REQ02 holds by construction.

4. Build sequence

1. **Image pipeline.** The golden AMI carries the EPM agent, registered to the EPM set covering DMZ servers, with the Credentials Rotation policy applied and the Windows Loosely Device platform assigned.
2. **Build pipeline.** Terraform provisions the safe through `cyberark_pvwa_safe`, named from the environment and application tags.
3. **Build pipeline.** Terraform launches the instance with the mandatory tags. No password is written to user data, Terraform state or anywhere else, so REQ12 is met by construction.
4. **Build pipeline to PVWA, TCP 443.** The build calls `POST /API/Accounts` to create the account object: device FQDN, the exact local username, the Loosely Device platform, no password. Keyed on the instance ID so retries and rebuilds cannot duplicate it.
5. **DMZ to PVWA, TCP 443 outbound.** The EPM agent contacts PVWA, authenticated by the security key established when the Credentials Rotation policy was configured.
6. **PVWA.** PVWA generates the password. The agent applies it to the local account and confirms. The vault now holds a credential that nothing else has ever seen.
7. **Steady state.** The agent rotates on the platform schedule. Nothing connects inbound to manage the credential at any point in the instance's life.
8. **Secure Zone to DMZ, TCP 3389.** ClientAPI launches recorded sessions through PSM using the vault-held credential.
9. **Termination.** The instance state change drives disposal of the account object, so dead hosts do not accumulate as permanent rotation failures.
10. **Periodic.** Accounts Discovery sweeps and reports any in-scope instance without a managed account, which is the backstop when step four or five fails.

5. Network and ports

Two rules at the DMZ boundary, both scoped to named source hosts and the tagged instance group.

Initiator	Destination	Port	Direction	Purpose
EPM agent on the instance	PVWA	TCP 443	DMZ outbound	Retrieve the credential, confirm rotation
PSM	DMZ instance	TCP 3389	Into the DMZ	Recorded session
Build pipeline	PVWA	TCP 443	Pipeline to on-premises	Safe provisioning and account creation
PSM	Vault	TCP 1858	On-premises	Credential retrieval, recording upload

Initiator	Destination	Port	Direction	Purpose
PVWA	Vault	TCP 1858	On-premises	Platform operation
ClientAPI and end users	PSM	TCP 3389	Corporate to on-premises	Session launch
Vault	Logging platform	Existing integration	On-premises	Audit export, REQ15

No SMB on 445, no RPC endpoint mapper on 135, no WMI and no dynamic port range, because nothing reaches in to rotate. The outbound rule needs REQ23 changed, which currently states that no connection carrying credential material is initiated from a DMZ host. The agent also needs whatever egress path the DMZ provides, and whether that requires a proxy is unconfirmed.

With PSM on-premises a recorded session crosses the site link, so administrative access to these servers depends on that link. A PSM in the Secure Zone removes the dependency and costs a change to where ClientAPI points.

6. SaaS variant

The shape is unchanged and three things move.

Element	Self-hosted	SaaS
Store and policy	Digital Vault with PVWA	Privilege Cloud
Session brokering	PSM as deployed	PSM role on a Connector, deployed into the Secure Zone, outbound only
Agent target	On-premises PVWA	The service endpoint
Account creation	REST call from the build	Identity Flows, low-code, no script
Safe provisioning	cyberark_pvwa_safe	cyberark_safe
Application consumption	Secrets Hub	Secrets Hub, natively
ClientAPI	Unchanged	Repointed at Privilege Cloud

The SaaS variant removes the site link from the credential path entirely, since the Connector and the agent both make outbound connections only. It costs a licensing model change and the ClientAPI repoint, and whether that repoint is configuration or development is the single largest unknown in this variant.

7. Options rejected

Options considered and set aside, with the reason for each. Where a requirement is the obstacle it is named, because a requirement that rules out a better answer is a requirement to revisit.

Option	Why not	Obstacle
CPM with the Windows Local Accounts plugin	The supported rotation path, and it needs a working credential before it can change anything, which is the problem being solved. It also connects over SMB on 445 to the remote SAM interface, or 135 plus a further port for the WMI variant, so it turns the design into a request to open lateral-movement protocols inbound to a DMZ.	REQ23
AWS key pair bootstrap using GetPasswordData	The platform generates and encrypts a first-boot password for the built-in Administrator account and for no other, while the build manages a purpose-created account, and hardened images commonly disable the built-in account anyway. Everything distinctive about it would be written and owned: key pair creation, storage, polling for password availability, decryption, onboarding, then disposal with evidence.	AS-10
Secrets Manager with the AWS IAM authenticator	The only CyberArk mechanism that lets a workload authenticate by its AWS identity, and genuinely good. The agent design means no workload needs to, so it would be a second licensed product doing a job already covered.	REQ25, REQ26
Credential Provider or Central Credential Provider on the instance	Authentication is by allowed machine, operating system user, application path, application hash or client certificate. There is no AWS IAM role or instance identity method, so a certificate would have to be delivered to every DMZ host and rotated there.	REQ13
AWS Systems Manager as the control channel	Removes the inbound rule at no licence cost, and enabling it hands anyone with the right IAM permission an interactive route onto the instance that PSM never records. The control closing that route is a policy that has to hold indefinitely.	REQ03, REQ24
Terraform, or the existing AWX pipeline, generating the password and handing it to the vault	Quickest to build and it keeps both custody weaknesses. Every credential the pipeline issues lands in Terraform state, plan output and job logs and stays usable until rotation completes, the controller holds a working credential for every host it manages, and the account is still established through the boot script.	REQ02, REQ12
AWS Secrets Manager as the credential store	Where the current pipeline puts the credential. No session isolation, no recording, no checkout and no single audit trail. Survives	REQ01, REQ03

Option	Why not	Obstacle
	only as a downstream mirror through Secrets Hub.	
Management components deployed inside the DMZ	Removes the management path into the zone by putting a vault-credentialed component in the least trusted part of the estate, which is also the hardest place to keep patched.	REQ22
Secure Infrastructure Access with ephemeral accounts	Creates a local account for the session and deletes it afterwards, so there is no standing credential, no bootstrap and no rotation. It answers the underlying risk more directly than this design does and it does not satisfy the requirements as written, which makes it a decision for you rather than a design judgement.	REQ01, REQ02

The CyberArk Terraform provider and Accounts Discovery were both assessed as the means of creating the account object and neither can do it, for the reasons in section 3. Both are retained in the design for the work they can do: safes and the assurance sweep.

Not assessed because they address a different problem: Secure Cloud Access, Cloud Visibility, Workforce Password Management, Secure Web Sessions, Secure Browser, IGA, Identity Compliance, Identity Administration, Remote Access, MSP Hub, the Application Server Credential Provider and PSM for SSH. The last applies the moment Linux enters scope. The Vault Conjur Synchronizer is superseded by Secrets Hub. PTA is not rejected, it detects misuse of what this design produces and sits alongside it.

8. Gaps

Verification and reconciliation are not supported

LCD supports credential changes only. Accounts with dependencies and account groups are also unsupported, which matters if any service or scheduled task uses the account. REQ10 requires drift between the vault and the target to be detected and remediated, and this design cannot do that natively.

Options: Change REQ10 to accept rotation without verification, with drift caught by the Discovery sweep and by rotation failures surfacing in the EPM console. Or keep REQ10 and accept a second mechanism, which reintroduces an inbound path for verification alone.

A separate licence

Credentials Rotation needs its own entitlement, and REQ26 states that no new licence tier is introduced unless no compliant alternative exists. The alternatives all carry substantial custom code, which is the argument, but it has to be made with a price against it.

Options: Price it at fleet size and approve it, or fall back to the Terraform-generated bootstrap and defend the state exposure instead.

An agent in the least trusted zone

The agent can change privileged credentials locally, so compromising it is a serious event. It goes in the golden AMI for new builds and needs a rollout to the existing population. It also needs an

outbound egress path from the DMZ, which may require a proxy. Whether agents are permitted on DMZ hosts is a policy question and has to be answered before anything is committed.

Rotation depends on agent health

If the agent stops working the credential cannot be rotated, and the same channel is the remediation path. The Discovery sweep catches the condition and does not fix it.

Options: Alert on agents that have not checked in within the agreed operational window, and treat a stale agent as a quarantine trigger under REQ19.

If a product question in section 9 comes back negative

If Credentials Rotation is unsupported on Windows Server or on machines with no domain membership, or if agents are not permitted in the DMZ, this design is unavailable and the fallback is CPM with the Windows Local Accounts plugin over SMB, bootstrapped by a Terraform-generated password. That carries the state exposure in the second gap above and the firewall request in section 7, and it needs no new licence.

9. To confirm before build

Every open item this design depends on. The first four decide whether it is viable at all. Items that belong to the requirements specification rather than to this design are held there.

Item	Assumed	Ask	If different
Credentials Rotation supported on Windows Server	Yes	CyberArk	Design unavailable, fall back to CPM
Supported on non-domain-joined machines	Yes	CyberArk	Design unavailable, fall back to CPM
Agents permitted on DMZ hosts	Yes	Security	Design unavailable, fall back to CPM
Outbound egress path from the DMZ, and whether a proxy is needed	Exists	Network	Design unavailable
A supported mechanism for creating the LCD account object automatically	None exists	CyberArk	The REST call is removed
Standing credential or ephemeral account	Standing	Security	Secure Infrastructure Access replaces this design
Who consumes the credential	ClientAPI and operators only	Application owners	Secrets Hub is built and REQ05 becomes a Must
Long-lived servers or auto-scaled capacity	Long-lived	Cloud team	Disposal becomes routine rather than exceptional

Item	Assumed	Ask	If different
ClientAPI's CyberArk integration needs no change	Producti on grade	ClientAPI owner	REQ04 becomes development, and relocating PSM becomes cheaper by comparison
Whether PSM can be relocated to the Secure Zone	Fixed by ClientAPI	ClientAPI owner	The site link leaves the session path
REQ10 changed to accept rotation without verification	Will be agreed	Security and platform	A second mechanism is needed for verification alone
REQ23 changed to permit the outbound agent call	Will be agreed	Network and security	Design unavailable
Fleet size, peak launch rate, regions, and the count of instances already on the AMI password	No figure	Cloud team	Sizes the licence, the agent rollout and the migration
Budget envelope for the entitlement	No figure	Budget holder	Decides the design on its own
Whether automated processes log in with this account	No	Server operation s	LCD does not support account dependencies, so those would need another answer

10. Next steps

1. **Decides whether this design applies.** Settle the standing credential question with security. If ephemeral accounts are acceptable, Secure Infrastructure Access replaces everything below.
2. **Confirms or kills the design.** Put the three product questions to CyberArk, and the agent policy question to security.
3. **Prices it.** Get the Credentials Rotation entitlement priced at fleet size, which needs the numbers from the cloud team first.
4. **Resolves the requirement conflicts.** Agree the REQ10 and REQ23 changes, or establish that they will not be made.
5. **Proves it.** Build one instance end to end in a lab: agent in the image, safe from Terraform, account object from the API call, rotation confirmed, session recorded. Then take it to design review.